

SSO Application – Technical Requirements Document (TRD)

Oct 9, 2026 · @Anubhav

Purpose and scope

This TRD turns the PRD requirements and the backend design into testable technical specifications for the SSO v1 release. It defines protocol behavior, interfaces, data handling, security controls, and acceptance criteria. Product intent lives in the PRD; service structure and data model live in the backend design.

In scope: SAML 2.0 and OIDC sign-on, SCIM 2.0 provisioning, MFA, sessions and single logout, admin API, audit logging, and the user portal back end.

Out of scope for v1: LDAP, Kerberos, password manager features, and external-customer identity (pending the open question in the PRD).

Protocol requirements: SAML 2.0 and OIDC

ID	Requirement	Acceptance check
SAML-01	Support SP-initiated and IdP-initiated flows	Both flows complete in the integration test suite
SAML-02	Sign assertions with RSA-SHA256; reject unsigned assertions	Unsigned assertion returns an error and no session
SAML-03	Assertions valid for 5 minutes, single use	Replayed assertion is rejected
SAML-04	Validate AudienceRestriction, Destination, and Recipient exactly	Mismatch on any field is rejected
SAML-05	Publish IdP metadata at a stable URL per tenant	Metadata validates against the SAML schema
OIDC-01	Authorization Code flow with PKCE (S256) required for all clients	Request without code_challenge is rejected

ID	Requirement	Acceptance check
OIDC-02	Access and ID tokens signed with ES256; JWKS published and cached	Token verifies against published JWKS
OIDC-03	Refresh tokens rotate on use; reuse of a rotated token revokes the grant	Reuse test returns invalid_grant and revokes
OIDC-04	ID token lifetime 5 minutes; access token lifetime 15 minutes	Token exp claims match configured values
OIDC-05	Redirect URIs matched exactly, no wildcards	Wildcard registration is refused by the admin API
OIDC-06	Discovery document at /.well-known/openid-configuration	Document validates against OIDC Discovery spec

Supported claims in v1: sub, email, name, groups, tenant_id. Claims are added only through a versioned change.

Provisioning requirements: SCIM 2.0

ID	Requirement	Acceptance check
SCIM-01	Implement /Users and /Groups per RFC 7643 and RFC 7644	Passes the chosen SCIM conformance suite
SCIM-02	Support create, read, update (PUT and PATCH), delete, and filter on userName and externalId	Each operation covered by a contract test
SCIM-03	Deactivation (active=false) revokes sessions within 5 minutes	Timed test measures revocation latency
SCIM-04	Idempotent writes keyed on externalId	Repeated POST returns the existing resource, not a duplicate
SCIM-05	Bulk operations disabled in v1	Bulk endpoint returns 501
SCIM-06	Per-tenant sync cursor; a failed batch resumes from the last acknowledged change	Fault injection test resumes without data loss

ID	Requirement	Acceptance check
SCIM-07	Authenticate with a per-tenant bearer token, rotatable without downtime	Rotation test with overlap window passes

Directory sync for Entra ID and Google Workspace runs on a schedule and on change notifications, with a nightly full reconciliation.

Session, token and key management requirements

ID	Requirement	Acceptance check
SES-01	Idle timeout 30 minutes (configurable 5 to 480); absolute timeout 12 hours (configurable up to 24)	Timer tests at boundary values
SES-02	Session state stored in Redis with PostgreSQL as system of record; write-through on change	Redis flush recovers sessions from PostgreSQL
SES-03	Single logout revokes the session and all issued refresh tokens, then notifies registered apps	Logout test shows every app session ended
SES-04	Session cookie: Secure, HttpOnly, SameSite=Lax, prefix __Host-	Cookie attribute check in integration tests
SES-05	Signing keys: RS256 and ES256 supported; ES256 default; 90-day rotation with 14-day overlap	Rotation test verifies old and new tokens during overlap
SES-06	Private keys never leave KMS; signing performed via KMS API	Code review and infrastructure policy check
SES-07	Token revocation list checked on userinfo and introspection calls	Revoked token returns inactive
SES-08	MFA step-up required for admin API writes older than 15 minutes	Stale-session write returns 401 with step-up challenge

Data, API and audit requirements

ID	Requirement	Acceptance check
DAT-01	All tenant-scoped tables include tenant_id; queries filtered in the data layer and enforced by PostgreSQL row-level security	Cross-tenant query test returns zero rows
DAT-02	Schema changes via versioned migrations, applied forward-only with a tested rollback plan	Migration test on a copy of production-shaped data
DAT-03	Personal data encrypted at rest (AES-256) and in transit (TLS 1.2 or higher)	Configuration scan passes
API-01	/v1 admin API versioned in the path; breaking changes require a new version	Contract test suite pinned per version
API-02	Error responses follow RFC 7807 problem details	Schema validation of every error response
API-03	Lists cursor-paginated; page size 1 to 200, default 50	Boundary tests at 0, 1, 200, 201
API-04	Rate limit 100 requests per minute per admin token, returns 429 with Retry-After	Load test confirms limit and header
AUD-01	Every admin action and sign-in event written to audit_events before the response is returned	Injected write failure returns 5xx and no change
AUD-02	Audit events append-only; no update or delete permissions for application roles	Permission check on the database role
AUD-03	Retention 365 days; partitions older than retention dropped by scheduled job	Job test on aged partitions
AUD-04	CSV export streams results and is capped at 1,000,000 rows per request	Export test on large fixture

Non-functional requirements with measurable targets

ID	Area	Target	Measured by
NFR-01	Availability	99.9% monthly for the auth path; 99.95% after year one	Synthetic probes every 30 seconds from three regions
NFR-02	Sign-in latency	Redirect round trip under 1 second at p95, excluding IdP latency	APM traces on gateway to Auth
NFR-03	Token issuance	p95 under 150 ms; p99 under 400 ms	Auth service metrics
NFR-04	Session lookup	p95 under 5 ms from Redis	Redis and service metrics
NFR-05	Throughput	500 sign-ins per second per region sustained, 1,500 burst for 60 seconds	Load test before each major release
NFR-06	Provisioning lag	Directory change reflected in app within 5 minutes at p95	Sync lag metric per tenant
NFR-07	Recovery	RPO 15 minutes; RTO 1 hour for the secondary region	Quarterly failover drill
NFR-08	Accessibility	Login and portal pages meet WCAG 2.1 AA	Automated scan plus manual audit before GA
NFR-09	Compliance	SOC 2 Type II controls operating; audit evidence retained	Annual audit report

Targets above are the release gates. Any miss on NFR-01, NFR-02, or NFR-05 blocks the GA release.

Environments, deployment and release requirements

Environment	Purpose	Data	Deploy trigger
Local	Developer work and unit tests	Synthetic fixtures only	Manual
Dev	Integration testing across services	Synthetic	Every merge to main
Staging	Pre-release verification, partner app testing	Anonymized copy of production shape	Release candidate tag
Production (primary)	Live tenants	Live	Approved release, staged rollout
Production (secondary)	Disaster recovery, warm standby	Replicated from primary	Follows primary

Release requirements

- Auth-critical changes (protocol code, key handling, session logic) require two approvals.
- Staged rollout: 5% of traffic for 30 minutes, then 50%, then 100%, with automatic rollback when the sign-in success rate drops below 99.5%.
- Feature flags for new protocol behavior, defaulting to off in production.
- Secrets injected at runtime from the secrets manager; none in code or images.
- Every production deployment produces an artifact with a software bill of materials.

Testing and acceptance criteria

Test levels

Level	Scope	Tooling	Gate
Unit	Functions, validators, token logic	Test runner per language	85% line coverage on protocol and session code
Contract	Admin API and SCIM endpoints	Schema-driven contract tests	100% of documented endpoints

Level	Scope	Tooling	Gate
Protocol conformance	SAML and OIDC against reference implementations	Certification suites and interop tools	All mandatory tests pass
Integration	Full sign-in across services and a test IdP	Ephemeral environment in CI	Green on every merge
Security	Auth bypass, injection, session fixation, token replay	Automated scanners and a manual pen test	No open high or critical findings
Load and soak	NFR-05 and a 24-hour soak	Load generator against staging	Targets in the NFR table met
Failover	Secondary region promotion	Scheduled drill	RTO and RPO met

Release acceptance

1. All PRD success-metric definitions are instrumented before beta.
2. Penetration test report reviewed; findings closed or formally accepted.
3. SAML and OIDC conformance results attached to the release record.
4. Failover drill completed in the last 90 days.

Dependencies, risks and open technical questions

Dependencies

- Microsoft Entra ID and Google Workspace APIs and change-notification limits.
- Managed PostgreSQL, Redis, and event queue services with SLAs that meet NFR-01.
- KMS availability; a KMS outage blocks token signing, so signing-key caching is evaluated in design review.

Risks

Risk	Impact	Mitigation
Vendor SAML implementations deviate from the standard	Failed app onboarding	Interop test harness; per-app setup guide

Risk	Impact	Mitigation
Clock skew breaks assertion validity windows	Intermittent sign-in failures	Allow 60-second skew; monitor skew per region
Provisioning rate limits from directory APIs	Sync lag above NFR-06	Backoff, batching, and nightly reconciliation

Open technical questions

- ☐ Which SCIM conformance suite is the reference for certification?
- ☐ Is the secondary region active-passive only, or does v1 need active-active reads?
- ☐ Do we accept a 60-second clock-skew allowance, or tighten it to 30 seconds?
- ☐ Which queue product is selected (see backend design open questions)?